

Intrusion Detection

كشف التسلل

Lecture 7 + Lecture 8

Treasure of the Lecture

ملخص امتحاني عربي مختصر وكامل، مع المصطلحات التقنية بالإنجليزي بجانب الترجمة العربية.

حفظ السريع: تعريفات، مقارنات، خطوات، رسومات مبسطة، ونقاط امتحانية مباشرة.

تحليل هيكل المحاضرتين / Lecture Structure Analysis

7 / Lecture 7 / المحاضرة

1. **Intruders** / المتسللون وأنواعهم.
2. **Intruder Behavior** / منهجية سلوك المهاجم.
3. **Intrusion Detection** / تعريف كشف التسلل.
4. **IDS Components** / مكونات نظام كشف التسلل.
5. **IDS Classification** / تصنيفات IDS.
6. **IDS Requirements** / متطلبات IDS الجيد.
7. **Analysis Approaches** / طرق التحليل.
8. **HIDS** / كشف التسلل المعتمد على المضيف.
9. **Distributed HIDS** / موزع HIDS وتصميمه.

8 / Lecture 8 / المحاضرة

1. **NIDS** / كشف التسلل المعتمد على الشبكة.
2. **Network Sensors** / حساسات الشبكة.
3. **NIDS Deployment** / أماكن نشر NIDS.
4. **Signature Detection** في NIDS.
5. **Anomaly Detection** في NIDS.
6. **NIDS Alerts** / معلومات التنبيهات.
7. **Distributed/Hybrid IDS** / موزع أو هجين.
8. **IDMEF/IDXP** / صيغة تبادل رسائل IDS.
9. **Honeypots** / مصائد الاختراق.

الخريطة الذهنية للحفظ: Exchange Format -> HIDS/NIDS/Hybrid -> IDS -> Behavior -> Intruder -> Honeypots.

مصطلحات أساسية يجب حفظها / Core Terms

المعنى الامتحاني المختصر	المصطلح / English Term
شخص أو جهة تستخدم أساليب اختراق لتجاوز أمن النظام؛ يسمى أحياناً Hacker أو Cracker.	Intruder / متسلل
فعل غير مصرح به يتجاوز آليات الحماية في النظام.	Security Intrusion / اختراق أمني
وظيفة Hardware أو Software تجمع وتحلل معلومات من الحاسوب أو الشبكة لاكتشاف اختراقات محتملة.	Intrusion Detection / كشف التسلل
نظام يراقب ويحلل الأحداث ثم يطلق Alert عند وجود نشاط مشبوه.	IDS / Intrusion Detection System
يراقب Host واحداً؛ ملفات، سجلات، Registry، System Calls.	HIDS / Host-based IDS
يراقب Traffic الشبكة Packet by Packet في نقاط مختارة.	NIDS / Network-based IDS
نظام خداعي يجذب المهاجم بعيداً عن الأنظمة المهمة ويجمع معلومات عن نشاطه.	Honeypot / مصيدة اختراق

المتسللون / Intruders

الفكرة الأساسية

من أهم تهديدات الأمن استخدام الاختراق بواسطة **Intruder**. فهم دوافع المهاجم يساعد في تصميم **Defensive Strategy** / استراتيجية دفاع مناسبة.

Classes of Intruders / أصناف المتسللين

الصف	الدافع / الهدف	احفظها هكذا
مجرمو الإنترنت / Cyber Criminals	أفراد أو مجموعات جريمة منظمة هدفها المكافأة المالية.	Money
ناشطون / Activists	دوافع اجتماعية أو سياسية.	Cause
جهات مدعومة من دولة / State-sponsored Organizations	تجسس أو تخريب برعاية حكومات.	/Espionage Sabotage
آخرون / Others	دوافع أخرى غير المذكورة.	Other motives

Classification of Skill Levels / مستويات المهارة

المستوى	الوصف	الكلمة المفتاحية
مبتدئ / Apprentice	مهارة تقنية قليلة؛ يستخدم Attack Toolkits جاهزة.	Use tools
متوسط / Journeyman	مهارة كافية؛ يعدل ويوسع أدوات الهجوم لاستغلال ثغرات جديدة.	Modify tools
محترف / Master	مهارة عالية؛ يكتشف أنواعاً جديدة من الثغرات أو يكتب أدوات هجوم قوية.	Create tools

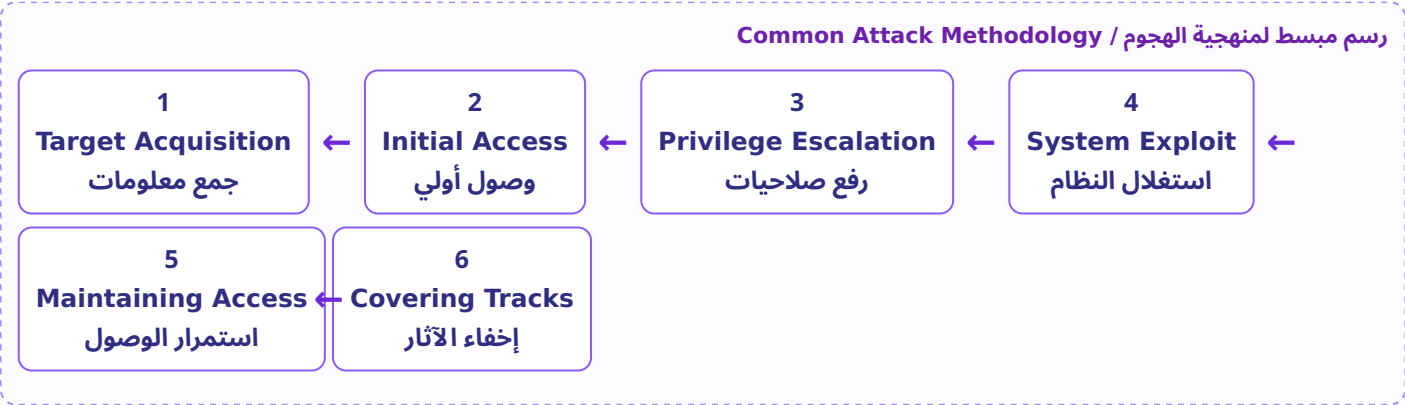
سلم المهارة: **Apprentice** يستخدم - **Journeyman** يعدل - **Master** يبتكر.

Examples of Intrusion / أمثلة على الاختراق

- تشغيل Packet Sniffer لالتقاط أسماء المستخدمين وكلمات المرور.
- استغلال خطأ صلاحيات في Anonymous FTP لتوزيع ملفات مقرصنة.
- الدخول عبر Modem غير آمن.
- Social Engineering: انتحال مدير والاتصال بالدعم لتغيير كلمة المرور.
- استخدام Workstation مسجلة الدخول بدون إذن.
- اختراق Root عن بعد لخادم البريد.
- تشويه موقع Web Server / Defacing.
- تخمين وكسر كلمات المرور.
- نسخ قاعدة بيانات بطاقات ائتمان.
- عرض بيانات حساسة بدون تصريح.

سلوك المتسلل / Intruder Behavior

تقنيات المهاجمين تتغير باستمرار لاستغلال ثغرات جديدة وتجنب الكشف، لكن غالباً يتبعون منهجية مشتركة.



المرحلة	المعنى المختصر	أمثلة من المحاضرة
Target Acquisition and Information Gathering تحديد الهدف وجمع المعلومات	تحديد الأنظمة المستهدفة وجمع معلومات عنها.	فحص موقع الشركة، DNS/WHOIS، استخدام NMAP، إرسال بريد للاستعلام، تحديد خدمات ضعيفة مثل Web CMS.
Initial Access الوصول الأولي	الدخول للنظام باستغلال ثغرة أو كلمة مرور.	Brute force لكلمة مرور CMS، استغلال Spear-phishing، Plugin، Brابط Exploit.
Privilege Escalation رفع الصلاحيات	زيادة صلاحيات المهاجم داخل النظام.	فحص تطبيقات لها Local Exploit، استغلال تطبيق ضعيف، تثبيت Sniffer، استخدام كلمة مرور Admin ملتقطة.
Information Gathering/System Exploit جمع معلومات أو استغلال النظام	تعديل موارد أو سحب معلومات مهمة.	فحص ملفات، نقل مستندات خارجياً، استخدام كلمات مرور للوصول إلى خوادم أخرى.
Maintaining Access الحفاظ على الوصول	ضمان عودة المهاجم لاحقاً.	Backdoor أو Rootkit، استخدام كلمة Admin لاحقاً، تعطيل Antivirus أو IDS.
Covering Tracks تغطية الآثار	إخفاء أدلة الهجوم.	Rootkit لإخفاء ملفات، تعديل Log Files وحذف آثار الاختراق.

إذا جاء سؤال: "رتب خطوات المهاجم" فالإجابة: **Maintain -> Exploit -> Escalation -> Access -> Recon -> Cover**.

Intrusion Detection System IDS / نظام كشف التسلل

التعريفات / Definitions

المفهوم	التعريف الامتحاني
اختراق / Security Intrusion أمني	Unauthorized act of bypassing security mechanisms / فعل غير مصرح يتجاوز آليات الأمن.
كشف / Intrusion Detection التسلل	Hardware/Software function تجمع وتحلل معلومات من مناطق مختلفة داخل Computer أو Network لتحديد اختراقات محتملة.

مكونات IDS / Components of IDS



المكون	وظيفته	أمثلة بيانات
الحساسات / Sensors	جمع المعلومات وإرسالها إلى Analyzer.	Network packets, Log files, System call traces.
المحلات / Analyzers	استقبال بيانات من Sensors أو Analyzers أخرى وتحليلها.	اكتشاف Patterns أو Anomalies.
واجهة / User Interface المستخدم	تمكين المستخدم من رؤية المخرجات أو التحكم في سلوك النظام.	Dashboard, Alerts, Configuration.

تصنيف IDS / Classification of IDS

النوع	ماذا يراقب؟	نقطة الحفظ
HIDS / Host-based IDS	خصائص Host واحد والأحداث عليه: Process IDs, System calls, Logs.	داخل الجهاز نفسه.
NIDS / Network-based IDS	Network Traffic ويحلل /Network/Transport Application Protocols.	على الشبكة والباكينات.
موزع / Distributed/Hybrid IDS أو هجين	يجمع بين Host-based و Network-based مع Central Analyzer.	دمج وربط معلومات من Sensors متعددة.

Requirements of IDS / متطلبات نظام كشف التسلل

أي IDS جيد يجب أن يحقق الآتي:

#	Requirement / المتطلب	المعنى المختصر للحفظ
1	Run continually	يعمل باستمرار مع أقل إشراف بشري.
2	Fault tolerant	يتعافى من crashes و re-initializations.
3	Resist subversion	يراقب نفسه ويكتشف إذا عدله المهاجم.
4	Minimal overhead	لا يسبب عبئاً كبيراً على النظام.
5	Configurable by policy	يمكن ضبطه حسب Security Policy.
6	Adapt over time	يتكيف مع تغير سلوك النظام والمستخدمين.
7	Scalable	يتوسع لمراقبة عدد كبير من Hosts.
8	Graceful degradation	إذا فشل جزء، تستمر بقية الأجزاء بأقل تأثير.
9	Dynamic reconfiguration	يمكن إعادة ضبطه بدون Restart.

احفظ المتطلبات كصفات نظام ناجح: دائم - متحمل - يحمي نفسه - خفيف - قابل لل ضبط - متكيف - scalable - يستمر عند الفشل - يعاد ضبطه ديناميكياً.

Analysis Approaches / طرق التحليل في IDS

الطريقة	الفكرة	متى تكون قوية؟	المشكلة
كشف / Anomaly Detection الشذوذ	يبنى نموذجاً للسلوك الطبيعي ثم يقارن السلوك الحالي به.	قد يكتشف هجمات جديدة غير معروفة.	قد ينتج False Positives إذا تغير السلوك الطبيعي.
كشف / Signature Detection بالتوقيع	يقارن النشاط الحالي مع Patterns معروفة لهجمات أو Malware.	دقيق وسريع للهجمات المعروفة.	لا يكتشف Zero-day إذا لا توجد Signature.
كشف / Heuristic Detection بالقواعد الاستدلالية	يستخدم Rules تصف هجمات معروفة أو استغلالات لضعف معروف.	أفضل من Signature الخام في بعض الحالات.	يعتمد على جودة القواعد وقد يخطئ.

كشف الشذوذ / Anomaly Detection

الفكرة



يتم أولاً بناء **Model of legitimate user behavior** من التشغيل الطبيعي في **Training Phase**، ثم يقارن السلوك الحالي بهذا النموذج في **Detection Phase**.

Approaches for Developing a Model / طرق بناء النموذج

الطريقة	شرح مختصر
إحصائية / Statistical	تحلل السلوك المرصود باستخدام نماذج Univariate أو Multivariate أو Time-series للقياسات.
معتمدة على المعرفة / Knowledge-based	تستخدم Expert System وقواعد تصف السلوك الشرعي.
تعلم الآلة / Machine-learning	تعلم نموذج تصنيف مناسب تلقائياً من Training Data باستخدام Data Mining.

Machine Learning Approaches / طرق تعلم الآلة

الفكرة الامتحانية المختصرة	الطريقة / Approach
تمثل علاقات احتمالية بين المقاييس المرصودة.	الشبكات البايزية / Bayesian Networks
تستخدم حالات States وانتقالات احتمالية، وبعض الحالات قد تكون Hidden.	نماذج ماركوف / Markov Models
تحاكي عمل الدماغ باستخدام Neurons و Synapses لتصنيف البيانات.	الشبكات العصبية / Neural Networks
يتعامل مع التقريب وعدم اليقين باستخدام Fuzzy Set Theory.	المنطق الضبابي / Fuzzy Logic
مستوحاة من التطور: inheritance, mutation, selection, recombination لبناء قواعد تصنيف.	الخوارزميات الجينية / Genetic Algorithms
تجمع البيانات في Clusters حسب التشابه أو المسافة وتحدد Outliers.	التجميع وكشف القيم الشاذة / Clustering and Outlier Detection

سؤال ظاهر في المحاضرة: Advantages and disadvantages of ML approaches?

الميزة: قد تكتشف هجمات جديدة وتتكيف مع بيانات كثيرة ومعقدة. العيب: تحتاج Training Data جيدة، وقد تنتج False Positives. وقد يكون تفسير القرار صعباً، وتحتاج موارد معالجة.

Host-based IDS HIDS / كشف التسلل المعتمد على المضيف

HIDS يضيف طبقة أمنية متخصصة على أنظمة حساسة أو ضعيفة مثل Database Servers و Administrative Systems.

الميزة الرئيسية لـ **HIDS**: يستطيع كشف **External Intrusions** و **Internal Intrusions**؛ وهذا لا تستطيع **NIDS** أو **Firewalls** فعله وحدها بنفس القوة.

Data Sources and Sensors for HIDS / مصادر بيانات HIDS

المصدر / Data Source	ماذا يعني؟	ملاحظات امتحانية
System Call Traces / تتبع نداءات النظام	تسجيل تسلسل System Calls التي تنفذها Processes.	تعمل جيداً في Unix/Linux.
Audit Log Records / سجلات التدقيق	معلومات يجمعها نظام التشغيل حول نشاط المستخدم.	مهمة لمعرفة ما حدث ومن فعله.
File Integrity Checksums / بصمات سلامة الملفات	فحص ملفات حرجة ومقارنة Checksum الحالي مع قيمة Known Good.	يكشف تغيير ملفات النظام أو العبث بها.
Registry Access / مراقبة سجل ويندوز	مراقبة الوصول إلى Windows Registry.	مهم في Windows لأن البرامج تعتمد كثيراً على Registry.

Anomaly HIDS / HIDS شذوذي

- أغلب العمل عليه كان في Unix/Linux بسبب سهولة جمع System Calls.
- الخوارزمية تقارن تسلسلات System Calls الحالية مع تسلسلات من Training Phase.
- تنتج **Mismatch Ratio** / نسبة عدم تطابق، ثم تقرر هل السلسلة Normal أو غير Normal.

Signature or Heuristic HIDS / HIDS بالتوقيع أو القواعد

- واسع الاستخدام في **Anti-virus / Anti-malware**.
- شائع في Windows، ويدمج أحياناً في Mail/Web Application Proxies على Firewalls.
- فعال في كشف Malware معروفة.
- لا يكشف **Zero-day** إذا لم توافق الهجمة Signatures أو Heuristic Rules معروفة.

مقارنة حفظ: Anomaly HIDS قد يرى الجديد لكنه يخطئ أكثر، Signature HIDS ممتاز للمعروف لكنه ضعيف أمام Zero-day.

Distributed HIDS / HIDS موزع

يقوم على التنسيق والتعاون بين أنظمة IDS عبر مجموعة Hosts موزعة داخل LAN أو Internetwork.

مكونات Distributed HIDS

المكون	وظيفته
وحدة وكيل / Host Agent Module المضيف	يجمع بيانات Security-related events على Host ويرسلها إلى Central Manager.
وكيل / LAN Monitor Agent Module مراقبة LAN	يحلل LAN Traffic ويرسل النتائج إلى Central Manager.
المدير / Central Manager Module المركزي	يستقبل التقارير من LAN Monitor و Host Agents، ثم يعالج ويربط Correlates التقارير لاكتشاف Intrusion.

رسم مبسط لمعمارية Distributed HIDS



Agent Architecture / معمارية الوكيل

المسار المبسط	الشرح
OS Audit Function -> Filter -> Reformat -> Host Audit Record	يجمع النظام Audit Information ثم يرشح الأحداث المهمة أمنياً ويعيد تنسيقها.
Host Audit Record -> Logic Module -> Analysis Module	يتم تحليل الأنشطة والتوقييع والجلسات المهمة.
Analysis Module -> Central Manager	إرسال Alerts واستقبال Query/Response من المدير المركزي.
Templates -> Logic/Analysis	قوالب وقواعد يمكن تعديلها لتوجيه الكشف.

Issues in Distributed HIDS Design / مشاكل التصميم

1. التعامل مع اختلاف **Sensor Data Formats** / صيغ بيانات الحساسات.
2. ضمان **Integrity and Confidentiality** للبيانات المرسلة عبر الشبكة.
3. اختيار **Centralized Architecture** قد يسبب Bottleneck، أو **Decentralized Architecture** قد يسبب مشكلة Coordination.

كشف التسلل / Network-based Intrusion Detection NIDS

المعتمد على الشبكة

تعريف وفكرة NIDS

- **NIDS** يراقب Traffic عند نقاط مختارة من Network أو مجموعة Networks متصلة.
- يفحص الحزم **Packet by Packet** في Real Time أو Near Real Time لاكتشاف Intrusion Patterns.
- قد يفحص نشاط **Network Layer** و **Transport Layer** و **Application Layer**.
- غالباً يكون جزءاً من **Perimeter Security Infrastructure** أو مرتبطاً بال Firewall.

مهم: NIDS لا يعمل جيداً عند وجود Encryption لأنه لا يستطيع رؤية Payload المشفر بوضوح.

NIDS Facility / مكونات منشأة NIDS

المكون	وظيفته
حساسات / Sensors	مراقبة Packet Traffic.
خوادم الإدارة / Management Servers	وظائف إدارة NIDS وتجميع النتائج.
واجهات الإدارة / Management Consoles	واجهة بشرية للمراقبة والتحكم.

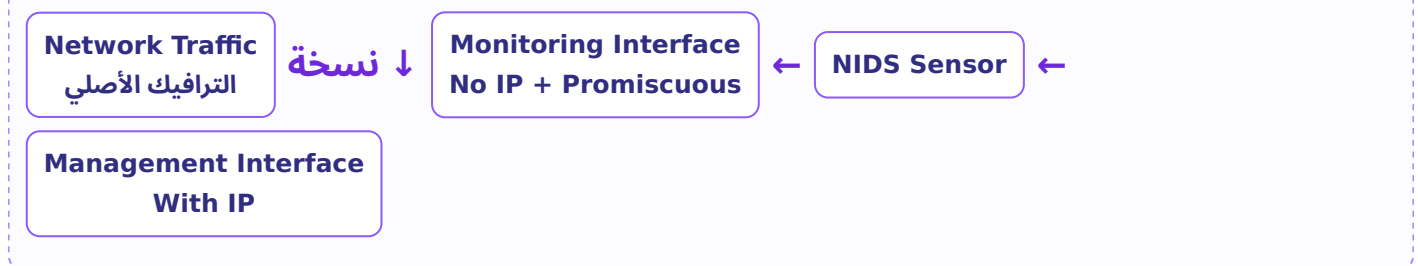
HIDS vs NIDS / مقارنة سريعة

المعيار	HIDS	NIDS
مكان المراقبة	داخل Host واحد.	على الشبكة عند نقاط مختارة.
نوع البيانات	Logs, System Calls, Registry, Files	Packets, Sessions, Protocols
كشف Internal Attacks	قوي إذا حدثت داخل Host.	قد لا يراها إذا لم تمر عبر نقطة المراقبة.
التشفير	قد يرى قبل/بعد التشفير داخل الجهاز.	ضعيف أمام Traffic مشفر.

أنواع حساسات الشبكة / Types of Network Sensors

النوع	التعريف	ماذا يستطيع؟	لماذا؟
Inline Sensor / حساس داخل المسار	يوضع داخل Network Segment بحيث يمر Traffic الحقيقي من خلاله.	IDS + IPS	لأنه يرى الترافيك ويمكنه Drop/Block/Modify قبل أن يصل.
Passive Sensor / حساس سلبي	يراقب نسخة من Traffic فقط، والترافيك الحقيقي لا يمر عبره.	IDS فقط غالباً	لأنه يكتشف ويرسل تنبيه، لكنه لا يتحكم مباشرة في مسار الحزمة الأصلية.

Passive NIDS Sensor / الرسم المبسط من المحاضرة



إجابة سؤال الشريحة:

- **Monitoring NIC** لا يحتاج IP لأنه لا يشارك في الاتصال؛ فقط يلتقط نسخة من الحزم في Promiscuous Mode.
- **Management NIC** يحتاج IP لأنه يتواصل مع الإدارة لإرسال Alerts واستقبال Updates/Configuration.

NIDS Sensor Deployment / نشر حساسات NIDS

لمنظمة لها عدة مواقع و LANs متصلة بالإنترنت، تحتاج Sensors في كل موقع لتحقيق استراتيجية NIDS شاملة.

موضع الحساس في الشكل	الهدف من المراقبة
قبل/حول External Firewall	رؤية الهجمات القادمة من الإنترنت قبل أو عند الحافة.
قرب Service Network / DMZ	مراقبة خوادم Web, Mail, DNS الأكثر تعرضاً.
قرب Internal Server/Data Networks	حماية الموارد الداخلية الحساسة.
قرب Workstation Networks	رصد إصابات المستخدمين، Scans، Worms، داخلية.

Intrusion Detection Techniques by NIDS

NIDS

مثل HIDS، يستخدم NIDS طريقتين رئيسيتين: **Signature Detection** و **Anomaly Detection**.

Attacks Suitable for Signature Detection / هجمات مناسبة للتوقيع

النوع	الشرح المختصر	أمثلة
Application Layer Reconnaissance and Attacks	تحليل بروتوكولات تطبيقات كثيرة.	,DHCP, DNS, FTP, HTTP, IMAP, IRC, NFS, POP, RPC, SIP, SMB, SMTP, SNMP, Telnet, TFTP, Database protocols, IM, P2P
Transport Layer Reconnaissance and Attacks	تحليل TCP/UDP وبروتوكولات نقل أخرى.	Port Scans, TCP attacks مثل SYN Floods.
Network Layer Reconnaissance and Attacks	تحليل IPv4, IPv6, ICMP, IGMP.	Spoofed IP Addresses, Illegal IP header values.
Unexpected Application Services	التحقق هل النشاط على Transport Connection يطابق البروتوكول المتوقع.	Host يشغل Unauthorized Application Service.
Policy Violations	مخالفة سياسة المؤسسة.	مواقع غير مناسبة، بروتوكولات تطبيقات ممنوعة.

Attacks Suitable for Anomaly Detection / هجمات مناسبة للشذوذ

النوع	Pattern / النمط الذي يكتشف
هجمات حجب الخدمة / DoS Attacks	Overwhelm the target / إغراق الهدف.
هجوم المسح / Scanning Attack	إرسال Packets مختلفة لمعرفة خصائص وثغرات النظام من الردود.
Application-layer Scanning	مثل Banner Grabbing.
Transport-layer Scanning	TCP/UDP Port Scanning.
Network-layer Scanning	ICMP Scanning.
الديدان / Worms	تنتشر سريعاً، اتصالات غير طبيعية، استخدام منافذ غير عادية.

Signature = معروف وله Pattern محدد. Anomaly = سلوك غير طبيعي مثل DoS/Scan/Worm.

/ Information of Alerts Collected by NIDS Sensors

معلومات تنبيهات NIDS

عندما يكتشف Sensor مخالفة محتملة، يرسل **Alert** ويسجل معلومات الحدث.

#	Alert Field / الحقل	المعنى
1	Timestamp	التاريخ والوقت.
2	Connection or Session ID	رقم متسلسل أو فريد لكل TCP Connection أو مجموعة Packets في Connectionless Protocols.
3	Event or Alert Type	نوع الحدث أو التنبيه.
4	Rating	.Priority, Severity, Impact, Confidence
5	Protocols	.Network, Transport, Application Layer Protocols
6	Source/Destination IP	عناوين IP المصدر والوجهة.
7	Source/Destination Ports or ICMP Codes	منافذ TCP/UDP أو أنواع وأكواد ICMP.
8	Bytes Transmitted	عدد البايتات المرسلة عبر الاتصال.
9	Decoded Payload Data	بيانات Payload مفككة مثل Requests/Responses.
10	State-related Information	معلومات حالة مثل Authenticated Username.

هذه القائمة مهمة جداً كسؤال تعداد: "اذكر معلومات Alert في NIDS".

الموزع أو الهجين / كشف التسلل

Distributed or Hybrid Intrusion Detection

لماذا ظهر؟

1. IDSs قد لا تتعرف على تهديدات جديدة، مما يؤدي إلى **False Positive** أو **False Negative**.
2. يصعب تحديث IDSs بسرعة كافية لمواجهة هجمات تنتشر بسرعة.

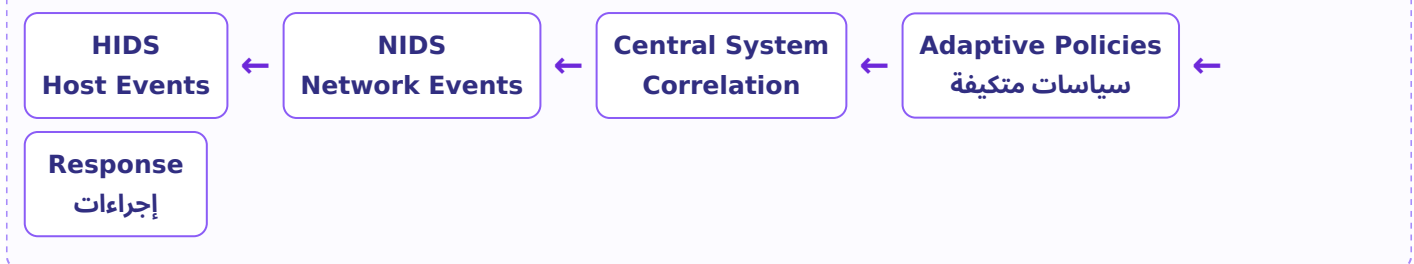
الفكرة

- بناء أنظمة متعاونة تستطيع التعرف على الهجمات من إشارات أكثر دقة ثم تتكيف بسرعة.
- يجمع Central System بين HIDS بتفاصيل Host-based Process و NIDS بأحداث الشبكة.
- يستخدم هذا الدمج لإدارة وتنسيق Intrusion Detection and Response في بنية المؤسسة.
- النظام المركزي يبدأ بـ Default Security Policies ثم يكيفها اعتماداً على Inputs من Distributed Sensors.

مدخلات توجه النظام المركزي / Inputs Guiding Central System

Input / المدخل	المعنى
أحداث ملخصة / Summary Events	أحداث من مصادر مختلفة تجمعها نقاط وسيطة مثل Firewalls أو IDSs أو Servers لخدمة جزء معين من الشبكة.
DDI Events / Distributed Detection and Inference	Alerts تنتج عندما تسمح Gossip Traffic لمنصة أن تستنتج أن هجوماً جارياً.
PEP Events / Policy Enforcement Points	تربط معلومات موزعة وقرارات محلية وإجراءات أجهزة لاكتشاف اختراقات قد لا تظهر على مستوى Host.

رسم مبسط لفكرة Hybrid/Distributed IDS



Intrusion Detection Exchange Format / صيغة تبادل كشف التسلسل

لماذا نحتاج Standards؟

- لتسهيل تطوير Distributed IDS تعمل عبر منصات وبيئات مختلفة.
- تدعم **Interoperability** / التشغيل البيني بين الأنظمة.
- محور ذلك هو **IETF Intrusion Detection Working Group**.
- هدف المجموعة: تعريف Data Formats و Exchange Procedures لمشاركة معلومات تهم IDS/Response Systems و Management Systems.

RFCs issued in 2007 / وثائق RFC

RFC	الاسم	المحتوى
RFC 4766	Intrusion Detection Message Exchange Requirements	يعرف متطلبات IDMEF.
RFC 4765	Intrusion Detection Message Exchange Format IDMEF	يصف Data Model لتمثيل معلومات تصدرها IDS ويشرح سبب استخدامه.
RFC 4767	Intrusion Detection Exchange Protocol IDXP	يصف بروتوكول تبادل رسائل كشف التسلسل.

Model for Intrusion Detection Message Exchange / نموذج تبادل رسائل IDS



المكون / Component	وظيفته
Data Source	البيانات الخام التي يستخدمها IDS لاكتشاف نشاط غير مصرح أو غير مرغوب.
Sensor	يجمع البيانات من Data Source ويرسل Events إلى Analyzer.
Analyzer	يحلل البيانات بحثاً عن نشاط غير مصرح أو أحداث تهم مسؤول الأمن.
Administrator	الشخص المسؤول عن Security Policy وقرارات نشر وضبط IDS.
Manager	يدير مكونات IDS: ضبط Sensors/Analyzers، إدارة Notifications، توحيد البيانات، التقارير.
Operator	المستخدم الأساسي لـ IDS Manager.

Honeypots / مصادد الاختراق

التعريف

Honeypot هو نظام خداعي **Decoy System** مصمم لجذب مهاجم محتمل بعيداً عن الأنظمة الحرجة.

أهداف Honeypots

- 1. منع أو إبعاد المهاجم عن الوصول إلى **Critical Systems**.
- 2. جمع معلومات عن نشاط المهاجم.
- 3. تشجيع المهاجم على البقاء في النظام وقتاً كافياً حتى يستجيب المسؤولون.

Honeypots تصنيف / Classification of Honeypots

النوع	التعريف	الميزة	الخطر/العيب
Low Interaction Honeypot مصيدة تفاعل منخفض	Software يحاكي خدمات أو أنظمة IT بما يكفي لتفاعل أولي واقعي، لكنه لا يشغل النسخة الكاملة.	أبسط وأقل خطورة.	معلومات أقل عن المهاجم.
High Interaction Honeypot مصيدة تفاعل عالي	نظام حقيقي بنظام تشغيل كامل وخدمات وتطبيقات متاحة للمهاجم.	معلومات أعمق وأكثر واقعية.	أكثر خطورة ويتطلب عزل ومراقبة قوية.

Honeypot أماكن نشر / Example of Honeypot Deployment

الموقع	الفائدة
خارج/قرب الإنترنت قبل الشبكة الداخلية	جذب الهجمات الخارجية ومراقبة محاولات الدخول.
داخل Service Network / DMZ	خداع مهاجم يستهدف Web/Mail/DNS.
داخل Internal Network	كشف مهاجم وصل للداخل أو حركة جانبية Lateral Movement.

Honeypot = Decoy + Delay + Data: يخدع، يؤخر، يجمع بيانات.

Final Cheat Sheet / الورقة الذهبية للحفظ

(1) أهم التعريفات

- **Security Intrusion** / اختراق أمني: تجاوز غير مصرح لآليات الأمن.
- **Intrusion Detection** / كشف التسلل: جمع وتحليل معلومات لاكتشاف اختراقات محتملة.
- **IDS**: Sensors + Analyzers + User Interface.
- **HIDS**: يراقب Host. **NIDS**: يراقب Network Traffic. **Hybrid**: يجمع الاثنين.
- **Honeypot**: نظام خداعي لجذب المهاجم وجمع معلومات عنه.

(2) قوائم مهمة للتعداد

السؤال المتوقع	الإجابة المختصرة
Classes of intruders	Cyber criminals, Activists, State-sponsored organizations, Others
Skill levels	Apprentice, Journeyman, Master
Attack methodology	Target acquisition -> Initial access -> Privilege escalation -> System exploit -> Maintaining access Covering tracks <-
IDS Requirements	Continuous, fault tolerant, resist subversion, low overhead, configurable, adaptive, scalable graceful degradation, dynamic reconfiguration
HIDS data sources	System calls, Audit logs, File integrity checksums, Registry access
NIDS alert fields	Time, Session ID, Type, Rating, Protocols, IPs, Ports/ICMP, Bytes, Payload, State info

(3) أهم المقارنات

المقارنة	احفظها
Anomaly vs Signature	Anomaly يبنى Normal Model وقد يكشف الجديد؛ Signature يطابق Patterns معروفة ولا يكشف Zero-day غالباً.
HIDS vs NIDS	HIDS داخل الجهاز؛ NIDS على الشبكة. HIDS يرى تفاصيل المضيف؛ NIDS يرى الحزم والبروتوكولات.
Inline vs Passive Sensor	Inline داخل المسار ويستطيع IPS؛ Passive يرى نسخة فقط وغالباً IDS فقط.
Low vs High Interaction Honeypot	Low يحاكي خدمات، أقل خطورة؛ High نظام حقيقي، معلومات أكثر وخطر أكبر.

(4) جمل امتحانية قصيرة

- **NIDS** لا يعمل جيداً مع Encryption لأنه لا يستطيع تحليل Payload المشفر.
- **HIDS** يمكنه كشف Intrusions داخلية وخارجية على Host حساس.
- **Distributed IDS** يقلل مشكلة عدم التعرف على التهديدات الجديدة ويساعد في التكيف السريع.
- **IDMEF** يوفر Data Model لتبادل معلومات IDS، و **IDXP** هو بروتوكول التبادل.
- **Monitoring NIC** في Passive NIDS لا يحتاج IP، و **Management NIC** يحتاج IP.

انتهى ملخص المحاضرتين 7 و 8: Intrusion Detection + Intrusion Detection cont